Highlights

Policy Without Enforcement? Web Security Posture of Canadian Public-Sector Websites

Isaac Lattia,Sina Keshvadi

- Foundational transport protections are widespread but uneven across Canadian public authorities: only 59.73% deploy HSTS and TLS 1.3 is negotiated less frequently than in domestic critical sectors and international peers.
- Defense-in-depth remains weakest at the application layer, with modern browser policy headers (CSP `frame-ancestors`, `Permissions-Policy`) and hardened cookie attributes rarely deployed, and only 1.1% of authorities publishing `security.txt`.
- Canadian authorities underperform both domestic critical sectors (finance, education, energy) and mandate-driven peers in the US and UK, indicating that recommendation-driven governance is associated with less consistent implementation of low-cost web security controls.

Policy Without Enforcement? Web Security Posture of Canadian Public-Sector Websites⋆

Isaac Lattia[a], Sina Keshvadi[a,*]

[a]Thompson Rivers University, 805 TRU Way, Kamloops, British Columbia, V2C 0C8, Canada

ARTICLE INFO

Keywords:
Web Security Measurement
Public-Sector Websites
Web Security Benchmarking
Security Headers
Internet measurement

ABSTRACT

Public-sector websites are trusted entry points for high-consequence services, yet their security posture depends on layered controls that extend beyond HTTPS adoption. We present a standards-aligned, non-invasive measurement study of web security configuration across Canadian public-sector authority websites, compared against domestic critical sectors (finance, education, and energy) and peer public-sector datasets in the United States and United Kingdom. In this paper, we distinguish origin-scoped transport controls (HTTPS enforcement, TLS posture, HSTS, disclosure signaling) from endpoint-scoped browser protections (security headers and cookie attributes) to reflect how users experience security after redirects. Across 375 Canadian authority origins, foundational transport protections are widespread but uneven: only 59.73% of HTTPS-reachable authority origins deploy HSTS, and authorities negotiate TLS 1.3 less frequently than comparable peers. Defense-in-depth is weakest at the application layer: modern policy headers (CSP frame-ancestors, Permissions-Policy) and hardened cookie defaults are rarely deployed. Only 1.1% of Canadian authority origins publish security.txt, while reconnaissance surfaces remain common. These results indicate that the primary gap is inconsistent implementation of low-cost, configuration-driven controls. Cross-sector and cross-jurisdiction comparisons suggest that more enforceable governance environments are associated with more uniform adoption of defense-in-depth protections.

1. Introduction

Public-sector websites have become a primary delivery channel for government information and services, enabling citizens to access essential resources, submit sensitive data, and make high-consequence decisions with legal, financial, and personal implications. In this context, security configuration directly shapes public trust, safety, and service continuity. The security posture of a modern web service is determined by multiple, interacting layers of controls, including transport protection (HTTPS/TLS), browser-enforced policies (e.g., HTTP Strict Transport Security (HSTS) and security response headers), secure session-management mechanisms (cookies), operational readiness for coordinated vulnerability disclosure, and disciplined suppression of implementation details that reduce attackers' reconnaissance advantage. HSTS, for example, is standardized in RFC 6797 and prevents SSL-stripping by enforcing HTTPS-only access at the user-agent level Hodges, Jackson and Barth (2012); Mozilla Developer Network (2024b). Similarly, contemporary guidance recommends prioritizing TLS 1.3 and disabling legacy protocol versions due to known weaknesses and downgrade risks Rescorla (2018); Moriarty and Farrell (2021); Barker and Davidson (2019); National Security Agency (2021); Canadian Centre for Cyber Security (2025a). Beyond transport, defense-in-depth is achieved through browser-side hardening controls such as Content Security Policy (CSP), clickjacking protections, and Permissions-Policy OWASP Foundation (2024b,a); Mozilla Developer Network (2024a), alongside secure cookie attributes that mitigate token theft Mozilla Developer Network (2025); OWASP Foundation (2024d). Finally, coordinated vulnerability disclosure is increasingly operationalized through standardized channels such as `security.txt` (RFC 9116), providing a low-cost mechanism to publish disclosure contacts Foudil and Shafranovich (2022); Cybersecurity and Infrastructure Security Agency (2023). Taken together, these layers imply that the practical question is no longer whether a site uses HTTPS, but whether it delivers robust, defense-in-depth protections across the web stack.

⋆This work was supported by the CSA Group Undergraduate Research Scholarship.

We gratefully acknowledge the support of the CSA Group Undergraduate Research Scholarship and thank CSA Group staff for their guidance during the project.

*Corresponding author

lattia11@mytru.ca (I. Lattia); skeshvad@tru.ca (S. Keshvadi)

ORCID(s):

Across jurisdictions, approaches to securing public-sector web services vary in the extent to which best practices are enforced. The United States and the United Kingdom have increasingly adopted mandate-driven approaches, relying on enforceable instruments such as the U.S. HTTPS-only policy (OMB Memorandum M-15-13) and Binding Operational Directives (BODs), as well as the UK Government Digital Service (GDS) security standards Office of Management and Budget (2015); Cybersecurity and Infrastructure Security Agency (2017); Government Digital Service (2024). In contrast, Canada operates primarily under a recommendation-driven model in which the Canadian Centre for Cyber Security (CCCS) issues technical guidance—for example, on securely configuring network protocols and related web-service protections—without an accompanying, centralized legal mandate that compels uniform adoption Canadian Centre for Cyber Security (2025a,b). This divergence motivates the central research question of this study: to what extent do Canadian authority websites implement these recommended best practices, and how does their implementation quality compare to other critical domestic sectors and international peers?

This paper addresses this question through a large-scale, automated benchmarking study. We collected data from 375 Canadian authority origins and performed parallel data collection across Canadian critical sectors (finance, education, and energy) as well as the equivalent sectors in the United States and the United Kingdom. Our evaluation framework integrates CCCS guidance with widely adopted standards to assess: (i) transport-layer protections; (ii) application-layer hardening; (iii) information-disclosure surfaces, including technology-revealing headers and error handling OWASP Foundation (2024c); MITRE Corporation (2024); and (iv) operational transparency via `security.txt` Foudil and Shafranovich (2022). A key design choice in our measurement is to distinguish *origin-scoped* controls (e.g., TLS configuration and HTTPS enforcement) from *endpoint-scoped* controls (e.g., security headers and cookie attributes observed at the final resolved landing page), to reflect on how protections are applied at different layers of the web stack.

Our findings indicate that although Canadian public-sector sites have broadly adopted foundational transport controls, they lag behind both international peers and domestic critical sectors in deploying more advanced defense-in-depth protections. This paper makes the following contributions:

1. Foundational transport protections are widespread but uneven across Canadian public authorities: only 59.73% deploy HSTS and TLS 1.3 is negotiated less frequently than in domestic critical sectors and international peers.
2. Defense-in-depth remains weakest at the application layer, with modern browser policy headers (CSP `frame-ancestors`, `Permissions-Policy`) and hardened cookie attributes rarely deployed, and only 1.1% of authorities publishing `security.txt`.
3. Canadian authorities underperform both domestic critical sectors (finance, education, energy) and mandate-driven peers in the US and UK, indicating that recommendation-driven governance is associated with less consistent implementation of low-cost web security controls.

The remainder of the paper is organized as follows. Section 2 reviews background and related work. Section 3 describes dataset construction, measurement units and preprocessing, the standards-aligned security tests, and scanner implementation and validation. Section 4 presents results across transport security, browser-enforced controls, disclosure readiness, and information leakage. Section 5 discusses implications for operators and policymakers and summarizes study limitations. Section 6 concludes the paper and outlines directions for future work.

2. Background and Related Work

2.1. Background

The security posture of a modern web service is a composite of multi-layered controls designed to provide defense-in-depth. In this paper, we categorize these controls into three functional domains: transport-layer security, application-layer hardening, and operational transparency.

Transport-Layer Security HTTPS protects the confidentiality and integrity of data in transit by layering HTTP over the Transport Layer Security (TLS) protocol. However, the presence of HTTPS alone does not guarantee a secure state. Misconfigurations, such as supporting weak cipher suites or legacy protocols (e.g., TLS 1.0 and 1.1), expose users to downgrade attacks and cryptographic interception Moriarty and Farrell (2021). Contemporary best practices, as defined by NIST and the CCCS, prioritize TLS 1.3 to leverage modern cryptographic primitives Rescorla (2018); Barker

and Davidson (2019); Canadian Centre for Cyber Security (2025a). Furthermore, HTTP Strict Transport Security (HSTS) is a critical policy mechanism (RFC 6797) that instructs browsers to interact with a domain exclusively over HTTPS, mitigating SSL-stripping and preventing users from bypassing certificate warnings Hodges et al. (2012); Mozilla Developer Network (2024b).

Application-Layer Hardening Modern browsers enforce a sophisticated suite of security policies delivered via HTTP response headers to mitigate application-level vulnerabilities. Central to this defense-in-depth approach is the Content Security Policy (CSP), a robust framework for constraining resource loading, such as scripts and frames, which serves as a primary mitigation against Cross-Site Scripting (XSS) and various data injection vectors OWASP Foundation (2024a); Mozilla Developer Network (2024a). These browser-side protections are further augmented by headers designed to prevent interface manipulation and content misinterpretation. For instance, `X-Frame-Options` and `X-Content-Type-Options: nosniff` are utilized to defend against clickjacking and MIME-sniffing attacks, respectively OWASP Foundation (2024b). Furthermore, since cookies remains the dominant mechanism for state management, the resilience of a web service to session hijacking is largely determined by their configuration. Attributes such as `Secure`, which restricts transmission to encrypted channels, `HttpOnly`, which prevents script-based token access, and `SameSite`, which limits cross-site request behavior, are essential for neutralizing session compromise pathways like token theft and Cross-Site Request Forgery (CSRF) Mozilla Developer Network (2025); OWASP Foundation (2024d).

Operational Transparency and Information Governance Beyond active technical defenses, the reduction of an organization's attack surface necessitates disciplined information governance and operational transparency. Unintentional disclosure of implementation details, such as technology-revealing `Server` or `X-Powered-By` headers and verbose error pages, provides attackers with a significant "reconnaissance advantage" by facilitating low-effort fingerprinting of the underlying software stack OWASP Foundation (2024c); MITRE Corporation (2024). Conversely, a high degree of operational maturity is signaled by the proactive adoption of standardized vulnerability disclosure channels. RFC 9116 defines `security.txt`, a machine-readable file placed at a well-known path that allows security researchers to report vulnerabilities efficiently and securely. This mechanism is increasingly advocated by international authorities, including CISA and the CCCS, as a low-cost yet high-impact step to strengthen national incident-response ecosystems and reduce the time-to-triage for discovered security flaws Foudil and Shafranovich (2022); Cybersecurity and Infrastructure Security Agency (2023); Canadian Centre for Cyber Security (2025b).

2.2. Related Work

Prior research into public-sector web security has primarily focused on large-scale HTTPS adoption and transport-layer configurations, yet these studies vary significantly in jurisdictional focus, measurement granularity, and the breadth of controls evaluated.

Empirical assessments of government web services have traditionally targeted single-nation populations or specific regulatory frameworks. Dunbar et al. proposed a scoring methodology for U.S. domains based on SSL/TLS support and HSTS presence, noting that advanced features like HSTS were infrequently deployed despite federal guidance Dunbar. Similarly, Schiavone et al. analyzed the adoption of transport security across 8,000 Italian municipality websites, finding that compliance with national regulations varied systematically by region and demographic profile Schiavone (2024). Beyond simple configuration, Hsiao et al. explored the concept of "cyber autonomy" among G7 government websites, revealing a high degree of dependence on third-party infrastructure and demonstrating how different policy environments—particularly centralized mandates—directly influence security adoption outcomes Hsiao, Kim, Ku, Chang, Chen, Chen, Wang and Jeng (2019).

A distinct body of literature focuses on the development of scanners for assessing specific web security layers. At the transport layer, platforms such as SSL Labs and longitudinal trackers like SSL Pulse provide Internet-scale insights into protocol support and cipher hygiene Qualys SSL Labs (2026); Qualys SSL Labs. For application-layer hardening, tools such as Mozilla's HTTP Observatory and SecurityHeaders.com provide header-focused grading for individual endpoints Mozilla (2026); Scott Helme (2026). While these platforms are invaluable for site-specific diagnostics, they are generally not designed for the systematic, multi-sector benchmarking of curated populations. Furthermore, existing scanners often treat security posture as a monolithic domain attribute, frequently failing to distinguish between transport properties at the host origin and application controls observed at final landing pages after a redirect chain.

Despite these advancements, the Canadian public-sector ecosystem remains significantly understudied. Most longitudinal analyses emphasize the U.S. and European landscapes, where binding mandates (e.g., BOD 18-01) often dictate security requirements. This leaves a critical gap in understanding how a recommendation-driven model, such as Canada's, performs in comparison to mandate-driven peers. Moreover, few studies integrate transport security, browser-side policy controls (CSP/HSTS), and operational disclosure readiness into a single unified framework aligned to specific national guidance. This paper addresses these gaps by providing a comparative analysis of Canadian authority and critical-sector websites against their U.S. and U.K. counterparts, utilizing a non-invasive scanner designed to operationalize CCCS, OWASP, and MDN specifications Canadian Centre for Cyber Security (2025a,b); OWASP Foundation (2024b); Mozilla Developer Network (2024b).

3. Methodology

This section describes the methodology used to construct our measurement datasets and to evaluate the web security posture of public-sector and critical-sector websites. We first define the target populations and explain how we compiled representative website lists for each sector and jurisdiction from authoritative sources. We then formalize the measurement units used throughout the study (URI, origin, and endpoint) and describe the preprocessing steps required to canonicalize targets and resolve redirects to the final measurable destinations. Next, we present the set of security controls evaluated by our scanner, explicitly distinguishing origin-scoped controls (e.g., transport and TLS configuration) from endpoint-scoped controls (e.g., browser-enforced headers and cookie attributes), as well as auxiliary probes for vulnerability disclosure and information leakage. Finally, we summarize the scanner implementation, ethical rate-limiting constraints, and validation procedures used to ensure the accuracy and reliability of automated classifications, along with the approach used to aggregate and analyze results across datasets.

3.1. Target Populations and Dataset Construction

We study four sectors whose public-facing web services either deliver core government functions or support critical societal infrastructure: (i) *public authorities* (government departments, agencies, and public bodies), (ii) *finance* (banks and credit unions), (iii) *education* (universities and colleges), and (iv) *energy* (electricity, oil/gas pipelines, and nuclear-related facilities). To contextualize Canadian deployment patterns, we construct comparable datasets from the United States and the United Kingdom where authoritative sources are available. Targets were assembled from authoritative registries, APIs, and official sector lists. Candidate URLs are later canonicalized and deduplicated through the preprocessing pipeline described in Section 3.2, to ensure that multiple source entries referring to the same hosted service are counted consistently. We include only *public-facing* web services intended for citizen, customer, or stakeholder access.

For Canada, authority websites are compiled from federal and provincial public directories and official listings, supplemented where necessary by regulator-maintained registries Government of Canada (2025); Treasury Board of Canada Secretariat (2025b,a); Transport Canada (2025b,a); Government of Canada. For Canadian finance, we include Schedule I and II member banks listed by the Canadian Bankers Association (CBA), complemented by provincial credit-union registries where authoritative listings are available Canadian Bankers Association (2024). For Canadian education, we use the Universities Canada membership list to identify public-facing universities and colleges Universities Canada. For Canadian energy, we use Electricity Canada's member list for the electricity sector, and regulator-maintained registries for interprovincial/international pipeline operators and licensed nuclear facilities Electricity Canada; Canada Energy Regulator; Canadian Nuclear Safety Commission. Where relevant, we also use sector association listings to capture additional operators (e.g., natural gas distribution entities) Canadian Gas Association.

For U.S. public authorities, we use the USA.gov agency index, which provides canonical contact and website references for federal entities U.S. Government. For U.S. finance, we use the FDIC BankFind Suite API, which provides institution records including primary internet web addresses U.S. Federal Deposit Insurance Corporation. For U.S. education, we use the U.S. Department of Education College Scorecard API, which provides institution-level records suitable for systematic sampling U.S. Department of Education.

For UK public authorities, we use the GOV.UK organisations endpoint (and related collections infrastructure) to obtain organisation records and associated public web presences UK Government Digital Service (b,a). For UK finance, we use the Bank of England's PRA-regulated banks list as the primary registry of regulated banks Bank of England – Prudential Regulation Authority. For UK education, we use the Discover Uni (formerly Unistats) dataset,

Table 1
Overview of website datasets and primary data sources.

Country	Sector	Primary data sources
Canada	Authorities	Compiled from Government of Canada official directories of departments and federal institutions Government of Canada (2025); Treasury Board of Canada Secretariat (2025b); remaining provincial authority lists were obtained from official provincial directories (manual lookup where no consolidated registry exists).
Canada	Finance	Schedule I and II banks from the Canadian Bankers Association Canadian Bankers Association (2024); credit unions from provincial regulator registries (manual consolidation).
Canada	Education	Public-facing universities and colleges from Universities Canada Universities Canada.
Canada	Energy	Electricity sector from Electricity Canada member list Electricity Canada; oil/gas and nuclear from federal regulator registries Canada Energy Regulator; Canadian Nuclear Safety Commission.
USA	Authorities	Federal agency index of U.S. government organizations U.S. Government.
USA	Finance	FDIC "BankFind" API U.S. Federal Deposit Insurance Corporation; sampling by ten most populous states based on U.S. population statistics U.S. Census Bureau.
USA	Education	U.S. Department of Education "College Scorecard" API U.S. Department of Education; sampling by ten most populous states based on U.S. population statistics U.S. Census Bureau.
USA	Energy	Edison Electric Institute list of member companies and their websites Edison Electric Institute.
UK	Authorities	GOV.UK Collections API (organization listings, filtered to "live") UK Government Digital Service (a).
UK	Finance	Bank of England PRA-regulated banks list Bank of England – Prudential Regulation Authority cross-referenced against the FCA FSDeveloper API Financial Conduct Authority.
UK	Education	Discover Uni dataset of higher-education providers Higher Education Statistics Agency (2024).
UK	Energy	No dataset was constructed; we did not identify an authoritative, URL-complete registry of UK energy providers.

which provides official provider/course metadata distributed by HESA and partner bodies Higher Education Statistics Agency (2024). For the UK, we include public authorities, finance, and education, and we omit UK energy because we did not identify a single authoritative registry that consistently publishes complete, URL-resolvable website fields for that sector.

Some source registries contain very large populations (notably U.S. finance and education). In those cases, we use a sampling strategy to retain geographic and institutional diversity while keeping measurement feasible at scale. Table 1 summarizes the resulting datasets (sizes by sector and jurisdiction) and the primary sources used to construct each list.

3.2. Measurement Units and Preprocessing

Throughout this study, we distinguish between three related units of analysis: *URIs*, *origins*, and *endpoints*. A *URI* refers to the input web address obtained from a registry or directory and may include a scheme, host, optional port, and a path (and in some cases query parameters). An *origin* is defined as the tuple `scheme + host + port` and represents the configuration boundary for transport-layer controls (e.g., TLS negotiation behavior and HSTS policy). An *endpoint* refers to a user-reached URI after following redirects and includes the path component. Endpoint-level responses are where browser-facing policies (e.g., security headers and cookie attributes) are observed. This distinction is central to our measurement design as some controls are naturally origin-scoped (transport security and disclosure mechanisms), while others are endpoint-scoped (browser-enforced policies and session attributes).

Input targets from source registries are first normalized to ensure consistent counting and to reduce duplicate measurement of the same hosted service. Hostnames are lowercased, and default ports are removed (80 for HTTP and 443 for HTTPS). Where an input omits an explicit scheme, we assign `https://` as the default to reflect modern expectations for public web services. For origin-scoped evaluation, we strip paths and queries to derive the canonical origin; for endpoint-scoped evaluation, we retain the full URI to reflect the page a user agent ultimately receives.

After canonicalization, we perform a redirect-resolution pass to map each input URI to the final user-reached destination. For each candidate URI, the scanner issues an HTTP `GET` request and examines the response status code. Any non-3xx response (e.g., `200 OK`, `403 Forbidden`) is treated as the final response. For 3xx responses with a `Location` header, the scanner follows the redirect target, recording each hop (status code and target URL) until a final non-3xx response is reached. To prevent unbounded redirect loops and to keep measurement non-invasive, we stop resolution if the chain exceeds a fixed hop limit (8 hops) or if a redirect response omits a `Location` header; such cases are tagged as resolution errors rather than followed indefinitely.

Redirect resolution yields two de-duplicated measurement sets. First, we derive a set of *unique origins* for origin-scoped tests by extracting origins from both the entry and final resolved destinations and de-duplicating across the combined set. Second, we derive a set of *final resolved endpoints* for endpoint-scoped tests, using only the final URI

after redirects (since this reflects what end users and browsers actually interact with). This design ensures that transport-layer posture is measured at the correct configuration boundary, while browser-enforced controls are measured on the user-reached response. Redirect resolution can substantially consolidate apparent populations when multiple directory-listed URLs ultimately converge on a small number of shared final origins (e.g., centralized government hosting). We explicitly report both pre-resolution and post-resolution counts (input URIs, final URIs, input origins, and unique measured origins) to make this consolidation transparent and to avoid over-counting replicated services.

Our preprocessing and subsequent measurements are designed to characterize observable configuration posture and information exposure, not to discover or exploit vulnerabilities. Accordingly, we do not perform authenticated crawling, do not submit forms or issue state-changing requests (e.g., `POST`), and do not run exploit payloads or intrusive fuzzing. All findings should therefore be interpreted as indicators of standards-aligned control adoption and observable leakage at the network and HTTP layers, rather than as a full security audit of each service.

3.3. Security Control Tests

For each target derived from the preprocessing pipeline (Section 3.2), the scanner applies a suite of tests that operationalize guidance from the Canadian Centre for Cyber Security (CCCS), relevant IETF RFCs, and widely adopted web-security recommendations (OWASP and MDN). Tests are grouped by the security layer they target and by their natural measurement scope: origin-scoped controls are evaluated at the `scheme+host+port` boundary, while endpoint-scoped controls are evaluated on the final user-reached URI after redirects. Across all modules, probes are designed to be non-invasive and rely only on standard protocol interactions and response parsing (no payload injection or authenticated crawling).

3.3.1. Transport Controls (origin-scoped)

We first measure baseline transport protections: HTTPS reachability, HTTP-to-HTTPS upgrade behavior, and HSTS deployment. For each origin, the scanner attempts connectivity over both `http://` and `https://`. To evaluate HTTPS-only enforcement, we issue an HTTP request and determine whether the origin upgrades the user to HTTPS via a redirect chain whose terminal URI uses the `https` scheme. We additionally record cases where HTTP responds without upgrade, since these represent user-accessible cleartext entry points.

To evaluate HTTP Strict Transport Security (HSTS), we check for the presence of the `Strict-Transport-Security` response header on HTTPS responses, as defined in RFC 6797 Hodges et al. (2012). When present, we parse the policy directives, including `max-age`, `includeSubDomains`, and `preload`. Following common operational practice and browser preload requirements, we classify an HSTS configuration as *strong* when it specifies a long `max-age` (at least one year) and includes subdomain coverage (i.e., `includeSubDomains`). We separately record preload signalling. These transport controls are treated as origin-scoped because they govern connection security and user-agent upgrade behavior at the origin level.

3.3.2. TLS Configuration (origin-scoped)

Beyond HTTPS availability, we profile each origin's Transport Layer Security (TLS) posture to determine (i) which protocol versions the service supports and (ii) which version is negotiated by a modern client in practice. TLS 1.3 is standardized in RFC 8446, and legacy TLS 1.0 and TLS 1.1 have been formally deprecated due to limited support for modern cryptography and increased downgrade risk (RFC 8996) Rescorla (2018); Moriarty and Farrell (2021). CCCS guidance similarly recommends prioritizing modern TLS configurations and disabling obsolete protocol versions Canadian Centre for Cyber Security (2025a).

For each origin, the scanner attempts constrained handshakes for TLS 1.3, TLS 1.2, TLS 1.1, and TLS 1.0 to record protocol support (success/failure per version). To approximate what typical users receive, we also perform a single *natural* handshake using a modern client configuration and record the negotiated protocol version. We report negotiated TLS versions rather than attempting to infer security from certificate properties or application-layer behavior, as our goal is to measure externally observable deployment posture at the transport layer.

3.3.3. Browser-Enforced Policies (endpoint-scoped)

We next evaluate browser-enforced security policies implemented via HTTP response headers on the final resolved landing-page endpoint. These controls provide defense in depth by constraining browser behavior even when application-layer weaknesses exist. Guided by OWASP and MDN recommendations, we record the presence of the following headers on the final endpoint response OWASP Foundation (2024b); Mozilla Developer Network (2024a):

- `Referrer-Policy`, which limits cross-origin referrer leakage and can reduce inadvertent disclosure of sensitive URL paths or parameters.
- `X-Content-Type-Options: nosniff`, which mitigates MIME-sniffing and content-type confusion behaviors in browsers.
- Clickjacking defenses via either `X-Frame-Options` or `Content-Security-Policy` framing restrictions. Because CSP offers the modern framing control, our CSP analysis focuses specifically on whether a `Content-Security-Pol` header includes the `frame-ancestors` directive; we record `X-Frame-Options` as a legacy but still-deployed control.
- `Permissions-Policy`, which restricts access to powerful browser features (e.g., camera, microphone, geolocation) and can reduce privacy and abuse surface in composite applications.

These tests are endpoint-scoped because header policies may vary by path, application component, or response type, and the final landing page represents the most consistent user-facing entry point for comparative measurement.

3.3.4. Session Cookie Attributes (endpoint-scoped)

Because cookies frequently carry session identifiers and user state, we measure baseline cookie-hardening attributes on the final endpoint response. For endpoints that set cookies (i.e., responses containing one or more `Set-Cookie` headers), we parse cookie attributes and record whether cookies include: (i) `Secure` (restrict transmission to HTTPS), (ii) `HttpOnly` (restrict JavaScript access), and (iii) `SameSite` (restrict cross-site sending). These attributes are widely recommended as baseline session protections Mozilla Developer Network (2025); OWASP Foundation (2024d).

To summarize adoption, we compute attribute prevalence among cookie-setting endpoints and classify cookie posture using a simple rule set: endpoints are considered *recommended* when cookies include `Secure` and `HttpOnly` and enforce a strict cross-site policy (e.g., `SameSite=Strict`); *sufficient* when `Secure` and `HttpOnly` are present with `SameSite=Lax` or stronger; and otherwise *insufficient*. Because cookie behavior can vary across application paths and user states, this study evaluates cookies on the public landing response only, and interprets results as an indicator of baseline hygiene rather than a complete session audit.

3.3.5. Vulnerability Disclosure (origin-scoped)

We assess operational readiness for coordinated vulnerability disclosure by probing for `security.txt`, a standardized, machine-parsable disclosure file defined in RFC 9116 Foudil and Shafranovich (2022). For each origin, the scanner issues `GET` requests to both `/.well-known/security.txt` (preferred location) and `/security.txt` (legacy location). A response is treated as a candidate `security.txt` file if it returns `200 OK` and contains minimally valid disclosure information (e.g., at least one `Contact:` field and/or a syntactically valid `Expires:` field). When present, we record field completeness (e.g., presence of `Contact`, `Expires`, and optional `Canonical`) and treat expired `Expires` values as operationally weak because they indicate outdated disclosure metadata. This test is origin-scoped because disclosure practices are typically managed at the site/operator level and are conventionally published per domain.

3.3.6. Information Leakage (endpoint + error-path probe)

Finally, we measure two forms of low-effort fingerprinting surface that commonly arise from configuration defaults: (i) technology-revealing response headers and (ii) error-handling disclosures. First, on the final endpoint response we check for the presence of headers that advertise server software, frameworks, or platforms (e.g., `Server`, `X-Powered-By`), using a curated list derived from OWASP guidance on removing revealing headers OWASP Foundation (2024c). When such headers are present, we additionally flag whether values appear to disclose explicit version strings, since version leakage can lower attacker reconnaissance cost and accelerate vulnerability targeting.

Second, to evaluate error-handling disclosure in a safe and consistent way, the scanner requests a deliberately non-existent path on each origin (a randomized tokenized 404 probe) to trigger the site's default error handler without sending exploit payloads. If the response returns textual content, we analyze the body for technology and version indicators using signature-based matching (e.g., common framework banners and version formats) and report whether any technology identifiers are disclosed. We do not attempt to validate exploitability; these tests are intended to measure observable configuration and disclosure surfaces only.

3.4. Scanner Implementation

The measurement pipeline was implemented as an automated scanner composed of modular probes corresponding to the control families described in Section 3.3. The scanner ingests the sector/jurisdiction target lists, applies the preprocessing pipeline (canonicalization and redirect resolution), and then executes the security-control modules in a fixed order while enforcing conservative resource limits to avoid disrupting production services.

Architecture and execution model The scanner is organized as a set of modular tests grouped by measurement scope. Preprocessing produces two deduplicated target sets: a unique *origin* set for origin-scoped tests (e.g., HTTPS reachability, HSTS parsing, TLS probing) and a unique *final endpoint* set for endpoint-scoped tests (e.g., security headers and cookie attributes). Each module consumes only the target set relevant to its scope, writes structured results to disk, and emits summary counters for monitoring progress. To improve throughput without overloading any individual service, the scanner uses bounded concurrency with both a *global* concurrency limit and a *per-origin* concurrency limit, to ensure that the scanner does not send bursts of requests to a single host.

HTTP behavior and redirect handling For all HTTP interactions, the scanner uses standard `GET` requests and processes responses according to the redirect resolution policy defined in Section 3.2. Redirect chains are followed up to a fixed maximum depth; if a chain exceeds the maximum, the scanner records an error state and does not continue. For each input URI, the scanner records the full redirect chain (status codes and `Location` targets), the entry URI, and the final resolved URI. The final resolved URI is then used as the canonical endpoint for endpoint-scoped tests, while origins derived from entry and final URIs form the origin set for origin-scoped tests. To reduce unnecessary traffic and ensure consistent parsing, redirect-resolution outputs (final endpoint, redirect chain metadata, and response headers) are cached for reuse across modules, so that subsequent tests do not repeat identical resolution work.

Rate limiting, timeouts, and stop rules (ethical scanning constraints) All network interactions are bounded by client-side timeouts and conservative retry/stop rules. We impose a strict global limit on concurrent in-flight requests and a smaller per-origin limit, implemented using semaphores. In our deployment configuration, authority datasets were scanned with at most 15 concurrent requests globally and at most 3 concurrent requests per origin; the remaining sectors were scanned with at most 20 concurrent requests globally and at most 5 concurrent requests per origin. Each HTTP request uses a 3-second timeout, and each TLS probing attempt uses a 3-second handshake timeout. To avoid repeated probing of hosts that appear to block automated traffic or are persistently unreachable from the scanner's vantage point, the scanner maintains per-origin failure counters and stops further HTTP modules after 3 consecutive HTTP failures and stops further TLS modules after 2 consecutive TLS failures. Origins that exceed these thresholds are marked as temporarily unavailable for the corresponding protocol and excluded from subsequent modules.

TLS probing implementation To measure protocol support, the scanner attempts constrained handshakes for TLS 1.3, TLS 1.2, TLS 1.1, and TLS 1.0 by configuring the client to offer only the targeted version and recording whether the handshake succeeds. To approximate the typical user experience, the scanner performs one additional *natural* handshake using a modern client configuration and records the negotiated protocol version (and, if enabled, negotiated cipher suite). TLS probing does not attempt certificate-path validation beyond what is required to complete the handshake; the objective is to measure externally observable configuration posture rather than to act as a full PKI validation tool.

Vantage point and scan window Measurements were conducted from a single external scanning vantage point hosted on the Google Cloud Platform (GCP) within the us-central1 region. The results therefore represent a cross-sectional snapshot of observable posture. The scanner records the scan start/end timestamps, software version, and configuration parameters (timeouts, concurrency limits, redirect depth, stop thresholds) to support reproducibility and interpretation of unreachable outcomes. Where services rate-limit, geofence, or block automated clients, our conservative stop rules capture this as an externally observable availability constraint rather than attempting to bypass defenses.

Output artifacts and reproducibility Each module emits machine-readable results (per-origin and per-endpoint records) along with aggregate summaries used in the Results section. Intermediate artifacts produced by preprocessing (canonicalized URIs, redirect chains, and deduplicated origin/endpoint sets) are retained to enable auditing of denominators and to support re-analysis. The scanner configuration (sector-specific concurrency limits, timeouts, and

stop thresholds) is treated as part of the experimental setup and is documented alongside the results. The full source code of our automated scanner, along with the raw measurement datasets and sector-specific target lists, are publicly available on GitHub Latta and Keshvadi (2026).

4. Results

This section reports measurement outcomes across the constructed datasets. We begin by characterizing dataset reachability and redirect-resolution outcomes to establish the effective denominators for subsequent adoption rates. We then present transport-layer posture (HTTPS/HSTS and TLS configuration) at the origin scope, followed by endpoint-scoped browser-enforced controls and session-cookie hardening, and finally operational readiness and information-governance outcomes. Unless otherwise stated, percentages are computed over the set of successfully measured targets for the relevant module.

4.1. Dataset Reachability and Resolution Outcomes

Before evaluating security controls, we first quantify how input targets resolve to measurable origins and endpoints and how often services are reachable from our scanning vantage point. This "pre-scan" stage serves two purposes. First, it determines the user-reached endpoints that form the basis of endpoint-scoped measurements (e.g., header and cookie observations). Second, it establishes the effective denominators for origin-scoped measurements by identifying which origins can be contacted successfully over HTTP and/or HTTPS under our conservative timeout and retry limits. Table 2 summarizes these resolution outcomes, including the number of input URIs, the number of final resolved URIs, the number of input origins, the resulting number of unique measured origins after consolidation, and the distribution of final status outcomes (`2xx` vs. error vs. no final URL).

Resolution success and error outcomes We classify each redirect-resolution attempt based on the terminal response observed after following redirects. Successful resolutions are those that terminate in a `2xx` response; terminal `4xx/5xx` responses indicate that the target was reachable but did not serve a successful landing response; and "no final URL" indicates that the scanner could not obtain a terminal response due to timeouts, connection failures, or invalid redirect behavior (e.g., missing `Location`). Because our subsequent measurements rely on the final resolved origin/endpoint, these categories directly determine which targets are included in later analyses. In particular, origin-scoped measurements exclude origins that never complete an HTTPS/TLS connection, while endpoint-scoped measurements exclude targets that do not resolve to a final landing response. Across datasets, a substantial fraction of input targets resolve to successful final responses, enabling downstream measurement. However, authority datasets exhibit noticeably lower final `2xx` rates than most critical-sector datasets. For example, among Canadian authority inputs, 68.4% resolved to final `2xx` responses, 5.2% ended in `4xx/5xx` errors, and 26.4% did not reach any final URL due to timeouts or connection failures under our limits. Comparable patterns are observed for U.S. authorities, while education, finance, and energy datasets generally achieve higher successful resolution rates.

Redirect-induced consolidation and shared infrastructure Redirect resolution often maps multiple input URIs to a smaller number of final destinations which reflects common operational patterns such as canonicalization (e.g., `www` → `apex`), centralized publishing platforms, and domain consolidation. This phenomenon is especially pronounced for U.K. authorities: hundreds of input URIs collapse to only a handful of unique final origins (348 origins mapping to 4 unique final origins), consistent with centralized government hosting and shared web infrastructure. We report both input and post-resolution counts to make this consolidation transparent and to avoid implicitly treating multiple redirected aliases as independent services. In later sections, origin-scoped results are computed over the set of unique origins and endpoint-scoped results over the set of final resolved URIs, reflecting the appropriate measurement unit for each control family.

The "unreachable" phenomenon and its implications Across jurisdictions, authority datasets tend to exhibit higher rates of unreachable outcomes relative to other sectors. Importantly, "unreachable" does not necessarily imply that a service is offline; rather, it indicates that repeated attempts could not complete the relevant HTTP response or TLS handshake within the imposed timeout, retry, and concurrency constraints. This pattern is consistent with the possibility that authority domains more frequently deploy aggressive bot-mitigation, WAF/CDN filtering, or rate-limiting policies that selectively degrade automated measurement traffic, even when the service is available to typical users. While we do not attempt to bypass these defensive controls, these outcomes remain relevant from an external perspective: if

Table 2
Redirect resolution summary (inputs mapped to measured endpoints).

Dataset	*n* URIs		*n* Origins		Final 2xx (%)
	Input	Final	Input	Unique	
CA Authorities	572	408	342	375	68.4
CA Education	96	91	95	103	94.8
CA Finance	156	142	155	157	89.1
CA Energy	229	207	188	188	92.6
US Authorities	434	314	351	373	72.4
US Education	51	48	51	53	92.2
US Finance	94	77	94	107	81.9
US Energy	141	120	126	141	84.4
UK Authorities	349	348	3	4	88.0
UK Education	354	303	354	447	85.3
UK Finance	141	125	140	165	88.7

Table 3
HTTP/HTTPS connectivity outcomes by dataset (percent of origins).

Dataset	*n* origins	HTTPS ok (%)	HTTPS unreach. (%)	HTTP ok (%)	HTTP→HTTPS (%)	HTTP no redir. (%)
CA Authorities	375	76.00	21.33	91.20	90.06	6.43
CA Education	103	95.15	4.85	100.00	96.12	1.94
CA Finance	177	94.35	5.08	97.18	97.09	1.74
CA Energy	214	90.65	8.41	98.60	93.84	3.79
US Authorities	373	73.46	26.27	94.10	94.59	4.84
US Education	53	94.34	5.66	98.11	98.08	1.92
US Finance	107	83.18	15.89	96.26	95.15	3.88
US Energy	141	84.40	15.60	99.29	89.29	5.71
UK Authorities	4	100.00	0.00	100.00	100.00	0.00
UK Education	417	89.21	10.07	94.48	95.69	2.28
UK Finance	165	89.09	9.70	94.55	91.03	8.33

automated and low-interaction clients are systematically blocked, a non-trivial class of legitimate users and monitoring systems may experience practical availability barriers. At the same time, some fraction of these outcomes may reflect genuine configuration errors or intermittent operational issues. For transparency, we treat unreachable outcomes as a distinct category in denominators and avoid inferring availability beyond what is observable from the measurement vantage point.

4.2. Transport Layer Security (Origin-Scoped)

This subsection characterizes origin-scoped transport protections, establishing the baseline security posture that underpins all subsequent browser- and application-layer controls. We report (i) HTTPS reachability and HTTP→HTTPS upgrade behavior, (ii) TLS protocol-version support and negotiated versions under a modern "natural" handshake, (iii) (where measured) TLS 1.2 cipher-suite quality, and (iv) HSTS deployment and configuration strength. Unless otherwise stated, transport results are computed over the set of unique origins produced after preprocessing (Section 3.2).

HTTPS reachability and HTTP→HTTPS upgrade success. Table 3 summarizes HTTP and HTTPS reachability by dataset, including whether HTTP-accessible services redirect users to HTTPS. Across most sectors, HTTPS is widely reachable and HTTP access typically redirects to HTTPS, indicating that encrypted transport is the default user experience. However, authority datasets exhibit weaker HTTPS reachability than other sectors. In particular, Canadian authority origins exhibit noticeable gaps relative to domestic critical sectors and international peers: a non-trivial fraction of authority origins remain unreachable over HTTPS from our vantage point, and a measurable share of HTTP-accessible origins do not upgrade users to HTTPS. This "HTTP without upgrade" behavior represents a persistent cleartext entry surface that contradicts modern HTTPS-only deployment expectations.

HTTPS enforcement asymmetry A particularly notable pattern in authority datasets is an asymmetry between HTTP and HTTPS reachability: some origins respond over HTTP yet are unreachable or fail during HTTPS negotiation

Table 4
TLS protocol support and negotiated versions by dataset (percent of origins).

Dataset	TLS support (%)				Negotiated (%)	
	1.3	1.2	1.1	1.0	1.3	1.2
CA Authorities	65.9	94.4	11.5	9.6	69.1	30.9
UK Authorities	100.0	100.0	0.0	0.0	100.0	0.0
US Authorities	83.9	99.5	3.2	2.9	84.6	15.4
CA Education	77.7	100.0	6.8	3.9	77.7	22.3
UK Education	81.5	95.7	8.9	8.4	84.6	15.4
US Education	79.2	100.0	17.0	18.9	79.2	20.8
CA Finance	94.4	97.7	3.4	2.3	95.4	4.6
UK Finance	88.5	98.2	4.2	4.2	90.2	9.8
US Finance	84.1	96.3	1.9	1.9	84.9	15.1
CA Energy	84.1	95.3	6.1	5.6	86.5	13.5
US Energy	78.7	98.6	2.8	2.8	79.9	20.1

(Table 3). From a user and monitoring perspective, this configuration undermines secure-by-default assumptions: an origin that reliably answers on port 80 but inconsistently supports port 443 can expose users to degraded privacy and integrity guarantees, even when the service nominally "supports HTTPS". While some portion of HTTPS failures may reflect active WAF/CDN filtering or bot mitigation (as discussed in Section 4.1), the practical outcome remains that secure transport is not uniformly available across all authority origins. Accordingly, we report HTTP and HTTPS reachability separately and treat HTTPS-unreachable outcomes as a distinct category rather than assuming service unavailability.

TLS protocol support and negotiated versions. We next evaluate TLS protocol posture by measuring (i) advertised support for TLS 1.3/1.2/1.1/1.0 and (ii) the protocol version negotiated in a natural handshake with a modern client. Table 4 reports protocol support and negotiated versions across datasets, and Figure 1 illustrates negotiated TLS versions for selected datasets to highlight cross-jurisdiction differences. Across all datasets, the natural handshake overwhelmingly negotiates modern TLS (TLS 1.3 or TLS 1.2), indicating that typical user agents are not falling back to deprecated protocol versions in practice. At the same time, we observe that legacy protocol support (TLS 1.0/1.1) remains enabled at non-zero rates in several datasets (Table 4), meaning that while modern clients negotiate modern TLS, the server-side configuration still exposes a larger attack surface than necessary. This distinction between *negotiated* versions and *supported* versions is important: disabling deprecated versions protocols reduces downgrade exposure and removes unnecessary attack surface, whereas leaving them enabled preserves compatibility at the cost of retaining formally deprecated options.

HSTS deployment and policy quality Finally, we evaluate whether HTTPS-capable origins deploy HSTS and whether policies meet common strength expectations. Table 5 reports HSTS presence among HTTPS-reachable origins and summarizes configuration strength using the presence of long-lived policies (via `max-age`), subdomain coverage (`includeSubDomains`), and preload signaling. A clear cross-jurisdiction gap emerges in authority datasets: Canadian authorities deploy HSTS less consistently than mandate-driven peers, and a substantial share of HTTPS-capable origins do not provide an HSTS policy at all. Among those that do, a subset meet strong-policy criteria (long duration with subdomain coverage), and an even smaller fraction signal preload eligibility, indicating that HTTPS is often deployed without the browser-enforced "safety net" that helps prevent downgrade and mixed-entry risks.

4.3. Application-Layer Hardening and Browser-Enforced Policies (Endpoint-Scoped)

While transport controls establish confidentiality and integrity in transit, modern web security also relies on browser-enforced policies that reduce exploitation impact and limit cross-origin abuse. This subsection reports adoption of browser-enforced hardening controls observable on the final, user-reached landing endpoints (i.e., after redirect resolution). Because these controls are delivered as HTTP response headers and may vary across paths and applications, all results in this subsection are computed over the set of *final resolved endpoints* for each dataset (Table 6).

Security header prevalence summary Table 6 summarizes adoption of key response headers that provide defense-in-depth against common web threats and privacy leakage: `Referrer-Policy`, `X-Content-Type-Options`,

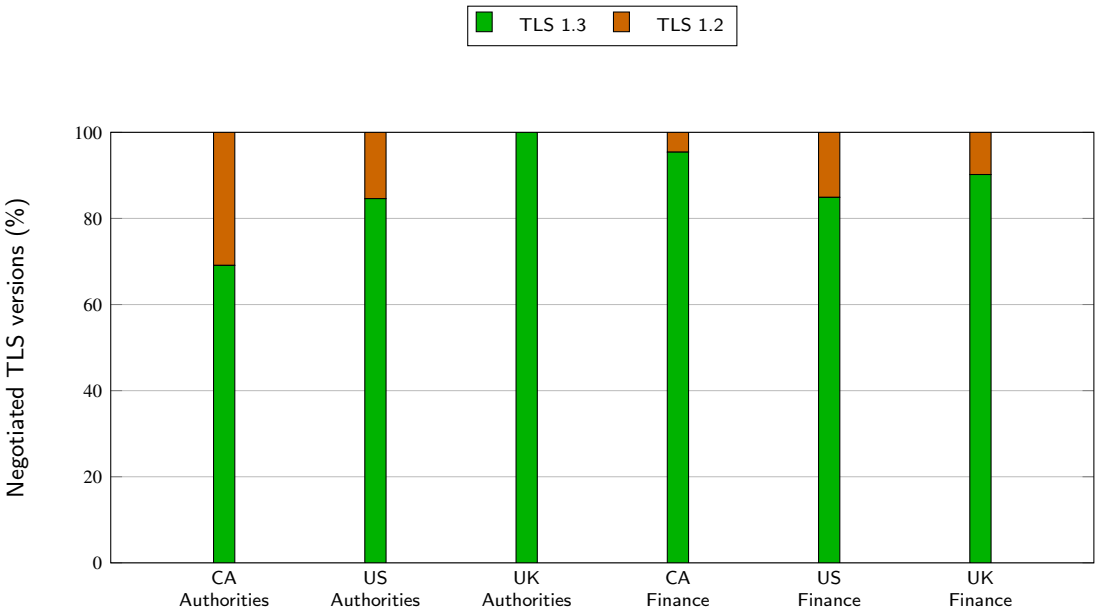

Figure 1: Stacked bar chart of negotiated TLS versions for authority and finance websites by country.

Table 5
HSTS adoption and strength among HTTPS-capable origins (percent of HTTPS-ok).

Dataset	Any HSTS (%)	Strong HSTS (%)	Preload (%)
CA Authorities	59.73	46.29	27.43
CA Education	55.67	33.33	20.37
CA Finance	78.57	34.85	23.48
CA Energy	58.46	49.12	21.05
US Authorities	89.74	64.90	55.51
US Education	62.00	19.35	22.58
US Finance	77.78	38.57	22.86
US Energy	75.63	53.33	21.11
UK Authorities	25.00	0.00	100.00
UK Education	54.81	35.12	23.41
UK Finance	85.91	52.34	34.38

`X-Frame-Options`, CSP with an explicit `frame-ancestors` directive, and `Permissions-Policy`. Across datasets, we observe a consistent pattern: "low-friction" headers that can be enabled with minimal application knowledge are deployed substantially more often than complex policy headers. In particular, `X-Content-Type-Options` and `X-Frame-Options` are commonly present across sectors, whereas `Content-Security-Policy` (CSP) and `Permissions-Policy` appear far less frequently. This gap is most pronounced in the Canadian authority dataset, where the adoption of modern browser policy controls lags behind both domestic critical sectors and international peers.

Adoption and Configuration of Security Headers. A consistent pattern emerges when contrasting "low-friction" headers with more "high-complexity" policies controls. Headers such as `X-Frame-Options` and `X-Content-Type-Options` are comparatively easy to deploy and are often supported directly by common web servers, frameworks, and reverse proxies, which helps explain their broader uptake across datasets. However, adoption drops significantly for controls that require deliberate policy specification or iterative tuning, such as `Referrer-Policy`, `Content-Security-Policy` (CSP), and `Permissions-Policy`. For example, CSP often requires iterative tuning to avoid breaking legitimate resource loads, and `Permissions-Policy` requires explicit decisions about which browser capabilities should be restricted for the top-level page and embedded contexts. The result is a visible "defense-in-depth gap" in which

Table 6
Security header adoption by dataset (percent of final URIs).

Dataset	Referrer Policy	X-Content-Type Options	X-Frame Options	CSP frame-ancestors	Permissions Policy
CA Authorities	17.4	62.3	63.5	17.9	8.6
CA Education	17.6	60.4	54.9	28.6	11.0
CA Finance	17.6	37.3	39.4	28.9	9.9
CA Energy	23.7	45.9	43.0	29.0	13.5
US Authorities	24.5	78.0	81.2	34.7	5.4
US Education	20.8	43.8	50.0	27.1	8.3
US Finance	28.6	64.9	67.5	53.2	11.7
US Energy	26.7	76.7	59.2	50.8	10.0
UK Authorities	0.0	87.6	87.6	87.4	87.6
UK Education	31.7	54.8	47.5	23.4	8.9
UK Finance	48.0	80.0	76.0	62.4	24.0

many sites deploy baseline hardening but fail to adopt stronger policy mechanisms enforced by modern browsers. For example, in the Canadian authority dataset, adoption rates for `X-Frame-Options` and `X-Content-Type-Options` are in the low-to-mid 60% range, whereas `Referrer-Policy` (17.4%), CSP `frame-ancestors` (17.9%), and `Permissions-Policy` (8.6%) are observed at substantially lower rates.

Because CSP policies differ widely in expressive power, rather than treating CSP as a binary indicator we specifically measure whether the policy includes `frame-ancestors`, which directly implements modern framing restrictions (clickjacking defense) at the browser level. Furthermore, we find that the prevalence of CSP `frame-ancestors` is significantly lower than that of the legacy `X-Frame-Options` header, indicating that many endpoints either omit CSP entirely or deploy it without the specific restrictions required for robust embedding control.

`Permissions-Policy` is the least prevalent of these controls. This low adoption is notable because, unlike CSP, `Permissions-Policy` is a low-cost mechanism to reduce exposure to powerful browser features (e.g., camera, microphone, geolocation) and can often be deployed incrementally by disabling unused features, including for embedded third-party content. Single-digit adoption suggests that proactive feature restriction is not yet standard practice in public-sector and critical-sector web deployments. As with CSP, presence does not guarantee a restrictive configuration. However, the rarity of the header implies that most measured endpoints are not explicitly declaring feature restrictions at all.

Overall, the comparative results suggest that while many services have adopted foundational hardening headers, modern browser policy mechanisms that require deliberate configuration remain under-deployed, particularly within the Canadian authority ecosystem.

4.4. Session Management and Cookie Security (Endpoint-Scoped)

This subsection evaluates session-management posture by analyzing cookie attributes observed on final resolved endpoints. Cookies are a common mechanism for maintaining state (including authenticated sessions as well as preferences and analytics identifiers), and their security attributes are enforced by user agents rather than application logic. Table 7 reports (i) how often endpoints set cookies on their landing responses and, conditional on cookie issuance (i.e., at least one `Set-Cookie` header), (ii) the prevalence of three baseline hardening attributes (`Secure`, `HttpOnly`, and `SameSite`), and (iii) an aggregate "Recommended/Sufficient" metric capturing whether sites meet a minimal defense-in-depth cookie profile. Across datasets, many landing pages do not set cookies, which is expected for informational services. Accordingly, attribute adoption is interpreted over the subset of cookie-setting endpoints. Within Canadian authorities, roughly 28% of endpoints set cookies, establishing the population for attribute-level evaluation in that sector.

Among cookie-setting endpoints, `Secure` is typically the most common attribute, reflecting the expectation that cookies should only be transmitted over HTTPS; `HttpOnly` is less consistently applied, and `SameSite` is the least consistently deployed. In Canadian authorities, approximately two-thirds (63.5%) of cookie-setting sites include the `Secure` flag and about half (48.7%) include `HttpOnly`, while only a small minority (15.7%) set `SameSite` to at least `Lax`. Critical-sector datasets (e.g., energy and finance) show different mixes of cookie issuance and attribute adoption, but none approach universal full hardening on issued cookies (e.g., the energy sector achieves only 4.9% recommended configurations). This pattern is operationally consequential because `HttpOnly` reduces exposure of session identifiers

Table 7
Cookie security flag adoption by country and sector.

Dataset	Sites w/ cookies (%)	Secure flag (%)	HttpOnly flag (%)	SameSite≥Lax (%)	Rec./Suff. (%)
CA Authorities	28.2	63.5	48.7	15.7	3.5
CA Education	35.2	43.8	50.0	0.0	0.0
CA Finance	63.4	32.2	83.3	1.1	1.1
CA Energy	39.6	74.4	76.8	13.4	4.9
US Authorities	29.0	51.6	44.0	7.7	3.3
US Education	33.3	62.5	68.8	0.0	0.0
US Finance	61.0	72.3	57.4	6.4	2.1
US Energy	46.7	58.9	42.9	8.9	7.1
UK Authorities	0.6	100.0	100.0	50.0	50.0
UK Education	45.5	71.0	69.6	13.0	3.6
UK Finance	44.0	80.0	70.9	14.5	9.1

to JavaScript-accessible theft in the presence of XSS, while `SameSite` provides a browser-level mitigation against cross-site request flows that can enable CSRF-style state changes.

To summarize whether cookie-setting endpoints achieve a minimal "gold standard" for baseline cookie protection, we compute the fraction of cookie-setting sites for which *all observed cookies* on the landing response satisfy the triple-attribute profile: `Secure` + `HttpOnly` + `SameSite` set to at least `Lax` (reported as "Recommended/Sufficient" in Table 7). The resulting rates are extremely low: for Canadian authorities, only about 3.5% of cookie-setting endpoints meet the recommended/sufficient profile despite much higher partial adoption of `Secure` and `HttpOnly`. These attributes are foundational to session security: `HttpOnly` reduces the exposure of session identifiers to JavaScript-accessible theft (XSS), while `SameSite` provides a browser-level mitigation against cross-site request flows that can enable CSRF-style state changes. This gap between partial and complete hardening highlights an important operational reality: cookie security is often not governed by a uniform policy baseline, and a missing attribute can leave session identifiers exposed to common web threats even when other controls are present.

4.5. Operational Readiness and Information Governance

This subsection evaluates two operational dimensions that materially affect real-world risk yet are largely configuration-driven: (i) whether organizations provide a standardized, machine-discoverable channel for coordinated vulnerability disclosure via `security.txt` (RFC 9116), and (ii) whether publicly reachable services unintentionally expose implementation details that reduce the cost of attacker reconnaissance. We operationalize the second dimension using two complementary measurements: technology-revealing HTTP response headers (e.g., `Server`, `X-Powered-By`) using OWASP-derived header lists, and disclosure in error-handling responses using our synthetic 404 probe. Results are summarized in Tables 8, 9, and 10.

Vulnerability-disclosure readiness is low across all datasets. Table 8 shows that only a small fraction of origins publish a `security.txt` file at standard locations, indicating that standardized disclosure is not yet routine practice for public-facing services. Canadian authorities are a clear outlier on the low end: only 1.1% of Canadian authority origins (4 of 375) publish `security.txt`. Among those few files, field completeness is generally good (all include `Contact` and `Expires`), but expiration hygiene is weak: only 25% of Canadian authority files have an unexpired `Expires` value at scan time. In contrast, peer authority datasets show higher adoption (e.g., U.S. authorities at 3.5%) and better maintenance among the files that do exist. Taken together, these results suggest that the primary limiting factor for Canadian authorities is *adoption* rather than syntactic correctness once deployed.

At the same time, information exposure that facilitates reconnaissance remains widespread. Table 9 shows that technology-revealing headers are present on the majority of sites in most datasets, but Canadian authorities are particularly exposed: 94.4% of Canadian authority origins emit at least one revealing header and many emit multiple such headers, indicating multi-layer stack disclosure (e.g., web server plus application framework). In contrast, Canadian finance demonstrates substantially better hygiene (only 53.5% expose any revealing header), suggesting that stronger incentives and operational practices can reduce avoidable disclosure. Error-handling responses further amplify this reconnaissance surface.

Table 10 shows that 47.2% of Canadian authority origins disclose technology identifiers in error responses, and 10.7% disclose explicit version information. From an adversarial perspective, this creates a meaningful "reconnaissance advantage": even a single version string can significantly narrow the search space for known vulnerabilities and

Table 8
Security.txt adoption and field completeness by dataset.

Dataset	n orig.	security.txt present		Contact (%)	Expires (%)	Valid exp. (%)
		Count	Share (%)			
CA Authorities	375	4	1.1	100.0	100.0	25.0
CA Education	103	4	3.9	100.0	100.0	100.0
CA Finance	177	1	0.6	100.0	0.0	0.0
CA Energy	214	9	4.2	100.0	66.7	100.0
US Authorities	373	13	3.5	100.0	92.3	83.3
US Education	53	3	5.7	100.0	33.3	100.0
US Finance	107	3	2.8	100.0	66.7	100.0
US Energy	141	1	0.7	100.0	100.0	0.0
UK Authorities	4	0	0.0	0.0	0.0	0.0
UK Education	417	24	5.8	100.0	75.0	83.3
UK Finance	165	20	12.1	100.0	50.0	60.0

Table 9
Distribution of technology-revealing headers by dataset.

Dataset	n sites	n revealing headers (%)				Any (%)
		0	1	2	3+	
CA Authorities	408	5.6	51.2	32.4	10.8	94.4
CA Education	91	17.6	37.4	40.7	4.4	82.4
CA Finance	142	46.5	38.7	13.4	1.4	53.5
CA Energy	207	14.5	48.8	28.5	8.2	85.5
US Authorities	314	19.4	36.9	29.6	14.0	80.6
US Education	48	8.3	68.8	14.6	8.3	91.7
US Finance	77	27.3	51.9	16.9	3.9	72.7
US Energy	120	35.8	17.5	36.7	10.0	64.2
UK Authorities	348	0.0	99.4	0.6	0.0	100.0
UK Education	303	14.2	47.2	35.0	3.6	85.8
UK Finance	125	31.2	48.0	20.0	0.8	68.8

Table 10
Information leakage in HTTP error responses by dataset.

Dataset	n origins	Any tech leak (%)	Version leak (%)
CA Authorities	375	47.2	10.7
CA Education	103	45.6	10.7
CA Finance	177	20.9	8.5
CA Energy	214	39.3	13.1
US Authorities	373	44.5	6.4
US Education	53	32.1	15.1
US Finance	107	31.8	3.7
US Energy	141	36.2	7.1
UK Authorities	4	50.0	0.0
UK Education	417	35.0	7.9
UK Finance	165	24.8	5.5

accelerate targeted exploitation planning. Despite the prevalence of technology banners and version disclosure, we observe an important positive control across all datasets: no origins leaked raw stack traces in the error responses detected by our signatures, indicating that the most severe class of debugging output is generally suppressed in production. Operationally, however, the combination of pervasive fingerprinting surface (headers and error pages) with near-absence of standardized disclosure channels (`security.txt`) is consequential: it lowers attacker effort while offering few uniform pathways for responsible reporting and coordinated remediation.

4.6. Cross-Sectoral and International Comparative Analysis

This subsection synthesizes the sectoral and cross-jurisdiction results to answer the central question of the study: whether a recommendation-driven model yields deployment outcomes comparable to mandate-driven peers, and where the largest practical gaps in defense-in-depth remain. We focus on two comparisons: (i) *Canada public vs. domestic critical sectors* (authorities vs. finance/energy) to assess whether public-sector posture lags behind regulated or market-incentivized sectors; and (ii) *Canada vs. mandate-driven peers* (U.S. and U.K.) to contextualize Canadian adoption patterns against jurisdictions with enforceable HTTPS and related security requirements. In the United States, HTTPS-only deployment is formalized through OMB Memorandum M-15-13 and reinforced through binding operational directives (e.g., BOD 18-01) that require concrete progress on web security controls. In the United Kingdom, central government guidance similarly requires HTTPS-only service delivery and recommends HSTS configurations suitable for preloading. In Canada, CCCS provides detailed technical guidance, but adoption is largely recommendation-driven rather than mandated across all public-sector web properties Office of Management and Budget (2015); Cybersecurity and Infrastructure Security Agency (2017); Canadian Centre for Cyber Security (2025a,b).

Within Canada, the most consistent pattern across layers is that *authorities underperform critical sectors* on several defense-in-depth controls. Canadian finance and energy sites generally exhibit stronger transport posture (higher HTTPS reachability, greater TLS 1.3 negotiation rates, and more uniform upgrade behavior) than authority sites (Sections 4.2–4.1). More importantly, the application-layer results indicate that Canadian authorities lag in deployment of modern browser-enforced controls (notably CSP `frame-ancestors` and `Permissions-Policy`) and show extremely low "full hardening" cookie configurations (Sections 4.3–4.4). Operational readiness exhibits the sharpest disparity: Canadian authorities have near-zero adoption of `security.txt` despite pervasive information disclosure surfaces (Section 4.5). Taken together, these patterns suggest that the Canadian public sector is not constrained by a lack of technical feasibility (since domestic critical sectors achieve stronger baselines), but rather by inconsistent adherence and configuration governance across authority web properties.

Cross-jurisdiction comparisons reinforce the hypothesis that governance environments shape observable deployment. Relative to U.S. (and U.K. authority datasets), Canadian authorities show lower HSTS adoption and weaker coverage of modern browser policy headers, alongside comparably low operational disclosure readiness (`security.txt`). These gaps align most clearly with controls that are low-cost yet require explicit policy decisions or centralized configuration management (e.g., HSTS, disclosure channels, and policy headers). This contrast is consistent with differences in enforcement regimes: U.S. federal policy requires secure connections for public services (OMB M-15-13) and DHS/CISA binding directives define compulsory actions and timelines for agency web security programs, while U.K. service guidance explicitly calls for HTTPS-only and HSTS configurations appropriate for preloading Office of Management and Budget (2015); Cybersecurity and Infrastructure Security Agency (2017). Canada's CCCS guidance is comparable in technical substance, but without an analogous centralized mandate for uniform adoption across authority properties Canadian Centre for Cyber Security (2025a,b). While measurement cannot prove causality, the convergence between (i) systematically higher adoption in mandate-driven peers and (ii) weaker and more variable adoption in recommendation-driven environments provides evidence that enforceability and accountability mechanisms are associated with more uniform deployment outcomes.

Across multiple layers, Canadian authorities fall below most visibly on (i) HSTS presence and strength, (ii) modern browser policy controls (especially CSP `frame-ancestors` and `Permissions-Policy`), and (iii) standardized disclosure readiness (`security.txt`). In contrast, differences are smaller for foundational HTTPS availability and for negotiation of modern TLS versions among reachable origins. The resulting pattern is consistent with a two-tier posture: Canada has broadly adopted baseline encryption for many services, but lags in the configuration-driven, defense-in-depth controls that transform "HTTPS present" into "HTTPS enforced and hardened". This compliance gap motivates the discussion in Section 5 on how configuration standards and governance mechanisms could be translated into more uniform operational practice across Canadian public-sector web services.

5. Discussion, Implications, and Limitations

This section interprets the empirical results and distills their implications for both operators and policymakers. We first summarize the study's key findings, emphasizing the main gaps that persist beyond baseline HTTPS deployment. We then discuss plausible technical and organizational explanations for these patterns, including the role of governance models in shaping adoption outcomes, while avoiding causal over-claims. Next, we translate the results into actionable

recommendations for practitioners and public-sector stakeholderss. These include recommendations we developed in collaboration with the CSA Group as part of the associated project deliverables, with the supporting report and artifacts made available in our public GitHub repository Latta and Keshvadi (2026). Finally, we present limitations that constrain interpretation and outline where the results should be treated as conservative lower bounds.

5.1. Key Findings

Our results reveal a consistent, cross-layer pattern: Canadian public-sector services have largely adopted foundational transport protections, but advanced, configuration-driven defenses are uneven and often under-deployed—particularly among authority websites—relative to both domestic critical sectors and mandate-driven international peers. This produces a two-tier posture in which "HTTPS present" is common, yet "HTTPS enforced and hardened" is not.

Most datasets exhibit high levels of HTTPS reachability and frequent HTTP→HTTPS upgrade behavior, indicating that encrypted transport has become a baseline expectation. However, Canadian authorities show weaker and less uniform outcomes: a non-trivial share of authority origins remain unreachable over HTTPS from our vantage point, and some origins respond over HTTP without reliably supporting HTTPS, creating an enforcement asymmetry. Even where HTTPS is available, browser-enforced upgrade protection remains incomplete: among HTTPS-reachable Canadian authority origins, only 59.73% deploy HSTS, meaning that a substantial fraction do not provide the user-agent-level safety net that helps prevent downgrade and mixed-entry risks. In parallel, modern TLS negotiation is common across datasets, but several populations still advertise legacy protocol support at non-zero rates, leaving unnecessary downgrade surface enabled even if modern clients negotiate TLS 1.3 or TLS 1.2 in practice.

Endpoint-scoped results show that low-friction hardening headers (e.g., `X-Frame-Options` and `X-Content-Type-Options` are adopted at moderate rates, while modern policy-driven controls drop sharply. This gap is particularly visible in Canadian authorities: CSP deployment with `frame-ancestors` and `Permissions-Policy` remain rare compared to legacy headers, indicating that many services have not yet adopted the browser-enforced controls that provide stronger defense-in-depth against clickjacking and feature abuse. These findings are consistent with the operational reality that policy-heavy controls often require deliberate design decisions, staged deployment, and maintenance to avoid breaking application functionality.

Among endpoints that set cookies, partial adoption of individual attributes (`Secure`, `HttpOnly`) is common, but complete baseline hardening remains rare. In Canadian authorities, roughly 28.2% of endpoints set cookies, yet only 3.5% of cookie-setting endpoints meet a minimal "recommended/sufficient" profile (i.e., `Secure` + `HttpOnly` + `SameSite` at least `Lax`). This gap between partial and complete hardening is operationally important: session and state cookies are only as strong as their weakest missing attribute, and inconsistent defaults leave common web threats insufficiently mitigated even when other controls are present.

A striking mismatch emerges between information exposure and disclosure readiness. Standardized vulnerability disclosure via `security.txt` is almost absent in Canadian authorities: only 1.1% of Canadian authority origins publish a `security.txt` file, and among those few files, expiration hygiene is often weak. This matters because `security.txt` is a low-cost, configuration-only mechanism that can substantially reduce friction for responsible reporting. In the absence of standardized disclosure, vulnerabilities discovered by external researchers are more likely to remain unreported or to be routed through ad hoc channels, delaying remediation.

Technology-revealing response headers are pervasive across datasets and especially prevalent in Canadian authorities (94.4% expose at least one such header). Error responses further amplify disclosure: 47.2% of Canadian authority origins leak technology identifiers in synthetic 404 responses, and 10.7% disclose explicit version information. From an adversarial perspective, these disclosures reduce reconnaissance cost and accelerate targeting. At the same time, we observe one consistent positive control across datasets: raw stack traces were not exposed in the error responses detected by our signatures, indicating that the most severe class of debugging output is generally suppressed in production.

Cross-sector and cross-jurisdiction comparisons converge on the same interpretation. Within Canada, finance and energy often achieve stronger and more consistent posture than authorities, suggesting that regulatory pressure and operational maturity can translate guidance into practice. Internationally, U.S. and U.K. authority datasets generally show more uniform adoption of several configuration-driven controls (notably HSTS and modern browser policies) than Canadian authorities. While measurement alone cannot establish causality, the systematic alignment between mandate-driven environments and more uniform adoption, versus recommendation-driven environments and more variable adoption, supports the central thesis of this paper: the remaining gaps are less about technical feasibility and more about incentives, standardization, and consistent implementation.

5.2. Explanations & Governance Interpretation

The results in Sections 4.1–4.5 indicate that the largest posture gaps are concentrated in configuration-driven controls that require consistent policy decisions and ongoing maintenance (e.g., HSTS strength, modern browser policy headers, cookie hardening, and disclosure readiness), rather than in the basic availability of HTTPS. Below we discuss plausible explanations for these patterns and interpret them through the lens of governance models, while emphasizing that our measurements establish associations rather than causality.

Configuration complexity and deployment friction A first explanation is that many of the under-deployed controls are not purely "turnkey" even when they are conceptually simple. CSP provides a clear example: although it can materially reduce the impact of content-injection classes, practical deployment often requires iterative tuning (e.g., auditing third-party dependencies and refactoring inline scripts) to avoid breaking legitimate functionality. Similarly, `Permissions-Policy` requires explicit choices about which browser capabilities should be enabled for top-level documents and embedded contexts, which may be unfamiliar to teams focused primarily on application delivery. Cookie hardening also suffers from coordination challenges: `Secure` and `HttpOnly` can often be enabled centrally, but consistent `SameSite` settings can require application-level review of cross-site flows and legacy integrations. These frictions plausibly explain the consistent pattern observed across datasets in which low-friction headers are deployed more widely than policy-heavy controls.

Decentralized ownership, vendor heterogeneity, and configuration drift Public-sector web ecosystems are commonly decentralized across many departments, agencies, and contractors, and often comprise heterogeneous stacks (multiple CMSs, frameworks, CDNs, and hosting providers). In such environments, security posture can degrade through configuration drift: a secure baseline may be applied to some properties but not others, or may erode over time as teams change, services are migrated, or third-party platforms are updated. This interpretation is consistent with two empirical observations in our data: (i) the high variability of defense-in-depth controls across authority sites compared to more uniform critical-sector deployments, and (ii) the strong consolidation effects observed in some datasets, where many organizations map to a small number of shared hosting origins. Shared infrastructure can raise the ceiling for uniform posture when centrally configured, but it can also mask uneven adoption if some services sit outside the centralized platform or if policy baselines are not enforced consistently across all tenants.

Measurement considerations: "unreachable" outcomes and defensive filtering. Finally, the higher rate of scanner-observed "unreachable" outcomes in authority datasets is consistent with more aggressive bot mitigation, WAF/CDN filtering, or rate limiting on government domains. Our scanner intentionally does not attempt to bypass defenses; instead, it reports what is observable under conservative, low-interaction requests. As a result, authority posture estimates may be conservative in the sense that some blocked services could implement stronger controls than we can observe. However, the operational implication remains relevant: aggressive filtering can also impede legitimate external monitoring and some user interactions, and it does not substitute for baseline configuration controls such as HSTS, secure cookie defaults, or disclosure readiness. We therefore treat reachability and filtering behavior as part of the externally observable security posture rather than as noise to be removed.

5.3. Recommendations (Operators + Policy)

The results suggest that many gaps in Canadian public-sector web posture are not driven by a lack of technical capability, but by inconsistent operationalization of well-known configuration practices. Importantly, several of the most impactful improvements can be implemented at the edge (e.g., CDN/WAF/reverse proxy) without application rewrites, while more complex policies can be deployed incrementally (e.g., introducing CSP framing restrictions first, then expanding CSP coverage). At a minimum, the baseline should include: HTTPS-only service delivery with strong HSTS, retirement of deprecated TLS versions and prioritization of TLS 1.3, a required set of browser-enforced hardening headers (with CSP `frame-ancestors` as the preferred framing control), default hardened cookie attributes for session/state cookies, mandatory publication of `security.txt`, and suppression of avoidable technology disclosure through response headers and error pages. Such a baseline can be implemented in stages (starting with edge-deployable controls) and integrated into routine operational monitoring to reduce configuration drift and improve uniformity across agencies and vendors.

From a governance perspective, the cross-sector and cross-jurisdiction comparisons suggest that Canada's primary challenge is consistency: similar technical guidance exists, but adoption is uneven. Accordingly, we recommend the

following policy directions to raise baseline posture across public authorities: (i) define and enforce a minimum public-sector web baseline, (ii) require periodic, automated posture measurement aligned with CCCS guidance and modern web standards, (iii) provide shared implementation support and templates, and (iv) normalize vulnerability disclosure for public services.

As part of this project, we worked with the CSA Group to translate the empirical findings into actionable recommendations for stakeholders. The corresponding CSA deliverable report and supporting artifacts are available in our public repository Latta and Keshvadi (2026)

5.4. Limitations

This study has several limitations that constrain interpretation of the results and motivate future extensions. First, our measurements reflect an *external* vantage point and a deliberately conservative, non-invasive scanning posture. Some origins were classified as "unreachable" when repeated attempts failed to complete an HTTP request or TLS handshake within the ethical timeouts and stop rules. These outcomes may arise from genuine service unavailability or misconfiguration, but they may also reflect active WAF/CDN bot mitigation, rate limiting, geo-dependent filtering, or reputation-based blocking. As a result, reported adoption rates should be interpreted as a snapshot of what is observable under low-interaction requests, and in some cases may represent conservative lower bounds for controls that could be present but not externally observable due to filtering.

Second, this work measures *deployment and configuration posture*, not exploitability. The absence of a control (e.g., HSTS, a policy header, or cookie attributes) indicates increased exposure to certain classes of web threats, but does not by itself establish the presence of a specific vulnerability or successful attack path. Conversely, the presence of a control does not guarantee correct implementation: for example, a site may emit a CSP header that is permissive, may apply secure cookie attributes to some cookies but not those relevant to authentication, or may deploy headers inconsistently across different application routes. Our results therefore represent a configuration-level benchmark rather than a penetration test or full compliance audit.

Third, endpoint-scoped measurements were performed on the *final resolved landing response* only. Some web applications may enforce stricter controls on authenticated pages, transactional flows, or high-value endpoints (e.g., login, payments, or account portals) that are not reachable without user interaction. Similarly, cookie behavior can change across routes and user states, and our cookie analysis captures what is set on the landing response rather than the complete session lifecycle. While the landing page is a consistent and comparable surface for large-scale benchmarking, it does not exhaustively represent the security posture of all application functionality.

Fourth, our `security.txt` discovery is intentionally conservative and may undercount deployments that centralize disclosure policy on a different origin. We probe the standard RFC 9116 locations on each origin but do not follow cross-origin redirects for `security.txt` discovery. Organizations that host disclosure metadata on a shared or centralized disclosure domain may therefore be underrepresented. Additionally, our validity checks emphasize the presence and freshness of key fields (e.g., `Contact`, `Expires`); they do not assess whether the referenced channels are actively monitored or whether reported issues receive timely responses.

Finally, the study is cross-sectional rather than longitudinal. Web configurations evolve rapidly due to platform migrations, CDN policy changes, certificate renewals, and incident-driven hardening. Our results therefore characterize the measured window rather than long-term trends. Longitudinal measurement would be necessary to quantify improvement over time, identify configuration drift, and evaluate the effect of policy interventions.

6. Conclusion and Future Work

This paper benchmarked the security posture of Canadian public-sector web services using a standards-aligned, non-invasive measurement methodology, with comparative baselines from the United States and the United Kingdom and additional comparison to domestic critical sectors (finance, education, and energy). By distinguishing origin-scoped transport controls from endpoint-scoped browser-enforced policies, session-cookie attributes, disclosure readiness, and information leakage surfaces, we provide a reproducible picture of what typical users and external observers encounter on the public web.

The results show that Canada has broadly adopted foundational transport protections, but that defense-in-depth remains uneven and frequently under-deployed within authority websites. While HTTPS is widely available and modern TLS versions are commonly negotiated by contemporary clients, enforcement and hardening controls are not consistently deployed. In particular, HSTS remains incomplete among Canadian authority origins that are reachable

over HTTPS, standardized disclosure via `security.txt` is almost absent (1.1% in Canadian authorities), and application-layer policy controls drop sharply relative to baseline headers. Cookie hardening exhibits the same pattern: although many authority endpoints set cookies, only a very small fraction meet a minimal baseline profile with `Secure+HttpOnly+SameSite` configured consistently. At the same time, information exposure remains pervasive: most Canadian authority origins emit technology-revealing headers and a substantial fraction disclose platform or version details in error responses, lowering the cost of attacker reconnaissance even when stack traces are correctly suppressed.

Cross-sector and cross-jurisdiction comparisons converge on a clear interpretation: the primary challenge is less about technical feasibility and more about incentives, standardization, and consistent implementation. Within Canada, regulated or market-incentivized critical sectors often achieve stronger or more uniform posture than authority websites, and internationally, mandate-driven environments exhibit more consistent deployment of several configuration-driven controls. Although measurement alone cannot establish causality, the alignment between enforceability and uniform adoption supports the central thesis of this work: closing the remaining gaps requires translating well-established guidance into consistently applied baselines, supported by accountability and continuous monitoring. This study provides an evidence-based baseline for that effort and a practical foundation for operators and policymakers seeking to strengthen the trust Canadians place in digital public services.

Future Work. This study motivates several extensions that would further strengthen the evidence base and increase operational utility. First, longitudinal measurements would quantify change over time, detect configuration drift, and enable evaluation of whether policy or operational interventions measurably improve adoption. Second, expanding endpoint coverage beyond landing pages (for example, authentication and other high-value workflows) would better capture how header policies and cookie attributes vary across application surfaces and user states. Third, multi-vantage scanning (e.g., from additional geographic regions and network environments) would help disentangle genuine unreachability from location-dependent filtering and bot-mitigation effects, improving interpretability of "unreachable" outcomes. Fourth, deeper directive-level analysis of policy headers (e.g., CSP source restrictions beyond `frame-ancestors`, and `Referrer-Policy` directive strictness) would allow posture assessment to move beyond presence/absence toward policy strength. Finally, integrating certificate-chain validation, certificate transparency signals, and basic DNS posture checks (e.g., CAA, DNSSEC where applicable) would provide a more holistic view of web service trust configuration beyond protocol negotiation alone.

Data & Code Availability

The scanner implementation, configuration templates, analysis scripts, and aggregated results used to generate the tables and figures in this paper are available in our public repository Latta and Keshvadi (2026). As part of this project, we also produced an extended technical report and recommendations deliverable in collaboration with the CSA Group, and this deliverable is included in the same repository.

Ethics Statement

All measurements were designed to be non-invasive and configuration-focused. The scanner issued only standard HTTP(S) `GET` requests, performed protocol handshakes, and followed redirects within a bounded depth. The study evaluates externally observable configuration posture and information exposure surfaces, and it does not attempt to validate exploitability or to access non-public resources. We did not authenticate, submit forms, issue state-changing requests (e.g., `POST`), or attempt exploitation. To minimize operational impact, we enforced conservative global and per-origin concurrency limits, short client-side timeouts, and strict stop thresholds for repeated failures.

CRediT Author Statement

Isaac Latta: Conceptualization, Methodology, Software, Data Curation, Investigation, Formal analysis, Visualization, Writing – original draft. Sina Keshvadi: Conceptualization, Methodology, Supervision, Writing – review & editing, Project administration.

Funding

This work was supported by the CSA Group Undergraduate Research Scholarship.

Acknowledgments

We gratefully acknowledge the support of the CSA Group Undergraduate Research Scholarship and thank CSA Group staff for their guidance during the project.

CRediT authorship contribution statement

Isaac Lattia: Conceptualization, Methodology, Software, Data Curation, Investigation, Formal analysis, Visualization, Writing – original draft. **Sina Keshvadi:** Conceptualization, Methodology, Supervision, Writing – review & editing, Project administration.

References

Bank of England – Prudential Regulation Authority, . List of pra-regulated credit unions. https://www.bankofengland.co.uk/-/media/boe/files/prudential-regulation/authorisations/which-firms-does-the-pra-regulate/2025/list-of-pra-regulated-credit-unions.csv.

Barker, E.B., Davidson, W.C., 2019. Guidelines for the Selection, Configuration, and Use of TLS Implementations. Special Publication 800-52 Revision 2. National Institute of Standards and Technology. URL: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-52r2.pdf.

Canada Energy Regulator, . Pipeline companies regulated by the cer. https://www.cer-rec.gc.ca/en/about/who-we-are-what-we-do/pipeline-companies-regulated-cer.html.

Canadian Bankers Association, 2024. Member Banks. URL: https://cba.ca/article/member-banks. the Canadian Bankers Association represents more than 60 domestic and foreign banks operating in Canada.

Canadian Centre for Cyber Security, 2025a. Guidance on Securely Configuring Network Protocols (ITSP.40.062). Practitioner series. Canadian Centre for Cyber Security. URL: https://www.cyber.gc.ca/en/guidance/guidance-securely-configuring-network-protocols-itsp40062.

Canadian Centre for Cyber Security, 2025b. Security Considerations for Your Website (ITSM.60.005). Management guidance. Canadian Centre for Cyber Security. URL: https://www.cyber.gc.ca/en/guidance/security-considerations-your-website-itsm60005.

Canadian Gas Association, . Industry links. https://www.cga.ca/resources/industry-links/.

Canadian Nuclear Safety Commission, . Nuclear facilities in canada. https://www.cnsc-ccsn.gc.ca/eng/resources/nuclear-facilities/.

Cybersecurity and Infrastructure Security Agency, 2017. Enhance Email and Web Security: Binding Operational Directive 18-01. Technical Report. U.S. Department of Homeland Security. URL: https://cyber.dhs.gov/assets/report/bod-18-01.pdf.

Cybersecurity and Infrastructure Security Agency, 2023. security.txt: A simple file with big value. URL: https://www.cisa.gov/news-events/news/securitytxt-simple-file-big-value.

Dunbar, D., . Survey of united states related domains: secure network protocol analysis. Available at SSRN 4240917 .

Edison Electric Institute, . Electric company member websites. https://www.eei.org/-/media/Project/EEI/Documents/About/member-company-web-sites.pdf.

Electricity Canada, . List of members. https://www.electricity.ca/membership/list-of-members/.

Financial Conduct Authority, . Fca public register api documentation. https://register.fca.org.uk/Developer/s/.

Foudil, E., Shafranovich, Y., 2022. A File Format to Aid in Security Vulnerability Disclosure. RFC 9116. Internet Engineering Task Force. URL: https://www.rfc-editor.org/rfc/rfc9116.html, doi:10.17487/RFC9116.

Government Digital Service, 2024. Security overview for websites. URL: https://gds-way.digital.cabinet-office.gov.uk/manuals/security-overview-for-websites.html.

Government of Canada, . Emergency management organizations in canada. https://www.canada.ca/en/services/policing/emergencies/preparedness/get-prepared/emergency-planning-resources/emergency-management-organizations.html.

Government of Canada, 2025. Departments and agencies. https://www.canada.ca/en/government/dept.html. Accessed: 2025-09-02.

Higher Education Statistics Agency, 2024. Discover Uni Dataset. Online. URL: https://www.hesa.ac.uk/support/tools-and-downloads/unistats.

Hodges, J., Jackson, C., Barth, A., 2012. HTTP Strict Transport Security (HSTS). Request for Comments 6797. Internet Engineering Task Force. URL: https://www.rfc-editor.org/rfc/rfc6797.

Hsiao, H.C., Kim, T.H.J., Ku, Y.M., Chang, C.M., Chen, H.F., Chen, Y.J., Wang, C.W., Jeng, W., 2019. An investigation of cyber autonomy on government websites, in: Proceedings of the Web Conference 2019 (WWW '19), ACM, San Francisco, CA, USA. URL: https://doi.org/10.1145/3308558.3313645, doi:10.1145/3308558.3313645.

Latta, I., Keshvadi, S., 2026. Website-Scanner: An automated framework for multi-layer web security benchmarking. https://github.com/IsaacLatta/Website-Scanner. Source code and raw measurement datasets for Canadian, US, and UK public-sector web services.

MITRE Corporation, 2024. Cwe-209: Information exposure through an error message. URL: https://cwe.mitre.org/data/definitions/209.html.

Moriarty, K., Farrell, S., 2021. Deprecating TLS 1.0 and TLS 1.1. RFC 8996. Internet Engineering Task Force. URL: https://www.rfc-editor.org/rfc/rfc8996.

Mozilla, 2026. Mozilla http observatory. https://github.com/mozilla/http-observatory. Accessed: 2026-01-18.

Mozilla Developer Network, 2024a. Content security policy (CSP) guide. URL: https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP.

Mozilla Developer Network, 2024b. Strict-transport-security — http header reference. URL: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security.

Mozilla Developer Network, 2025. Secure cookie configuration. URL: https://developer.mozilla.org/en-US/docs/Web/Security/Practical_implementation_guides/Cookies.

National Security Agency, 2021. Eliminating Obsolete TLS. Technical Report. National Security Agency. URL: https://media.defense.gov/2021/Jan/05/2002560140/-1/-1/0/ELIMINATING_OBSOLETE_TLS_U00197443-20.PDF.

Office of Management and Budget, 2015. M-15-13: Policy to Require Secure Connections across Federal Websites and Web Services. OMB Memorandum M-15-13. Executive Office of the President of the United States. URL: https://obamawhitehouse.archives.gov/sites/default/files/omb/memoranda/2015/m-15-13.pdf.

OWASP Foundation, 2024a. Content security policy (csp) cheat sheet. URL: https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html.

OWASP Foundation, 2024b. Http security response headers cheat sheet. URL: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.html.

OWASP Foundation, 2024c. Owasp secure headers project. URL: https://owasp.org/www-project-secure-headers/.

OWASP Foundation, 2024d. Session management cheat sheet — cookies. URL: https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#cookies.

Qualys SSL Labs, . SSL Pulse. Qualys SSL Labs Projects. URL: https://www.ssllabs.com/ssl-pulse/. accessed: 2026-01-18.

Qualys SSL Labs, 2026. Ssl server test. https://www.ssllabs.com/ssltest/. Accessed: 2026-01-18.

Rescorla, E., 2018. The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446. Internet Engineering Task Force. URL: https://datatracker.ietf.org/doc/html/rfc8446, doi:10.17487/RFC8446.

Schiavone, A.G., 2024. Municipality2https: A study on https protocol's usage in italian municipalities' websites. Computers & Security 137, 103592.

Scott Helme, 2026. Securityheaders.com. https://securityheaders.com/. Accessed: 2026-01-18.

Transport Canada, 2025a. List of canada port authorities. URL: https://tc.canada.ca/en/marine-transportation/ports-harbours-anchorages/list-canada-port-authorities. accessed list of maritime port authorities.

Transport Canada, 2025b. List of small airports owned by transport canada. URL: https://tc.canada.ca/en/aviation/operating-airports-aerodromes/list-airports-owned-transport-canada. accessed list of small airport authorities.

Treasury Board of Canada Secretariat, 2025a. List of crown corporations. URL: https://www.canada.ca/en/treasury-board-secretariat/services/guidance-crown-corporations/list-crown-corporations.html. accessed list of Crown corporations.

Treasury Board of Canada Secretariat, 2025b. List of government of canada institutions. URL: https://www.canada.ca/en/treasury-board-secretariat/services/access-information-privacy/access-information/info-source/list-institutions.html. accessed federal institutions list.

UK Government Digital Service, a. Collections api documentation. https://docs.publishing.service.gov.uk/repos/collections/api.html.

UK Government Digital Service, b. Collections api endpoint. https://www.gov.uk/api/collections.

Universities Canada, . Our members – list of canadian universities. https://univcan.ca/about-universities-canada/our-members/.

U.S. Census Bureau, . Population statistics and demographic data. https://www.census.gov/topics/population.html.

U.S. Department of Education, . College scorecard api documentation. https://collegescorecard.ed.gov/data/api-documentation.

U.S. Federal Deposit Insurance Corporation, . Fdic bankfind api endpoint. https://api.fdic.gov/banks/institutions.

U.S. Government, . A–z index of u.s. government departments and agencies. https://www.usa.gov/agency-index.